

Proyecto tercer parcial ISO 2701 Seguridad informática.

Edgar Omar Rodriguez Hernandez 177888

Ivan Ros Padilla 177573

Estefano Alessandro Rodriguez Morin 178584

Josué Emmanuel López López 182078

Mauricio Josafat Salinas Carrilo 177406

Aaron Efraím Mata Martínez 179419

Universidad Politécnica de San Luis Potosí

Mtro. Servando López Contreras

Contenido

Introducción y descripción de la empresa	2
Historia	3
¿Quién está detrás de Telegram?	3
Objetivos estratégicos.....	3
Misión y Visión	3
Organigrama	3
Organización	4
Alcance	5
Normas ISO/IEC 27000	6
Norma Seleccionada: ISO/IEC 27001:2022	6
Cláusulas 4 a 10	6
B. El Anexo A (Los Controles de Seguridad)	6
3. Áreas y Procesos Específicos a Proteger en Telegram	7
Proceso A: Ciclo de Vida de Desarrollo de Software (SDLC) Seguro	7
Proceso B: Gestión de la Infraestructura y Servidores Distribuidos	7
Proceso C: Criptografía y Gestión de Claves	8
4. Justificación de por qué se utiliza esta norma (ISO 27001) en Telegram	8
1. Proporcionalidad y Adaptabilidad al Tamaño del Equipo	8
2. Blindaje contra la Ingeniería Social y la Amenaza Interna	8
3. Armonización Legal Internacional (Compliance)	8
4. Enfoque Basado en Riesgos para la Autonomía Financiera	9
Referencias normativas.....	9
Activo en Cuestión	10
Revisión de Términos y Condiciones (T&C) vs ISO 27001	10
Activos Internos	10
Activos Externos:.....	12
Términos y Definiciones de la ISO 27000 (Aplicables a Telegram)	15
Matriz de riesgos	15
I. Riesgo Extremo (16 - 25)	16
II. Riesgo Muy Alto (10 - 15)	16
III. Riesgo Medio / Bajo (04 - 09)	17
Definir la Ley dentro del Marco de Referencia	18





Introducción y descripción de la empresa

Es una aplicación de mensajería enfocada en la velocidad y seguridad, es súper rápida, simple y gratuita. Puedes usar Telegram en todos tus dispositivos al mismo tiempo. Tus mensajes se sincronizan a la perfección a través de cualquiera de tus teléfonos, tablets o computadoras. Telegram es una de las 5 apps más descargadas del mundo con más de 1000 millones de usuarios activos.

Historia

Creada en 2013 por los hermanos Pável y Nikolái Dúrov como una plataforma de mensajería totalmente encriptada, Telegram actualmente supera los 500 millones de usuarios activos tras la migración masiva de usuarios de Whatsapp en enero del 2021 en busca de un nuevo canal de comunicación con políticas de protección de datos y seguridad más estrictas.

¿Quién está detrás de Telegram?

Telegram es apoyado por Pavel Duróv y su hermano Nikolai. Pavel apoya a Telegram financiera e ideológicamente, mientras el aporte de Nikolai es tecnológico. Para hacer Telegram posible, Nikolai desarrolló un protocolo de datos personalizado y único, que es abierto, seguro y optimizado para trabajar con múltiples centros de datos. Como resultado, Telegram combina seguridad, confiabilidad y velocidad en cualquier red.

Objetivos estratégicos

Misión y Visión

Garantizar el derecho a la privacidad y la libre comunicación global mediante tecnología de vanguardia, accesible y gratuita.

Convertirse en la infraestructura de comunicación más segura y eficiente del mundo, redefiniendo los estándares de libertad digital y autonomía del usuario.

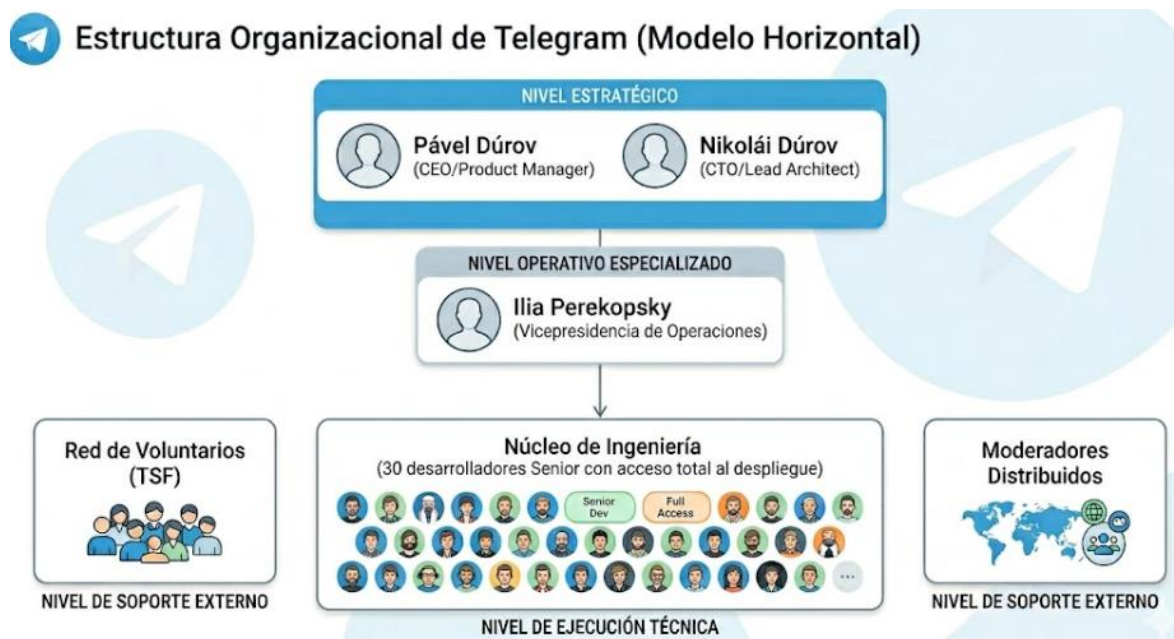


SECCIÓN 1: ALCANCE

Organigrama

Estructura: Organización Horizontal (Flat Structure)

- **Nivel Estratégico:** Pável Dúrov (CEO/Product Manager) y Nikolái Dúrov (CTO/Lead Architect).
- **Nivel Operativo Especializado:** Vicepresidencia de Operaciones (Ilia Perekopsky).
- **Nivel de Ejecución Técnica:** Núcleo de Ingeniería (30 desarrolladores Senior con acceso total al despliegue).
- **Nivel de Soporte Externo:** Red de Voluntarios (TSF) y Moderadores distribuidos.



Organización

Telegram opera bajo una filosofía de minimalismo radical, funcionando más como una startup tecnológica de élite que como una corporación multinacional. Su estructura es extremadamente horizontal y carece de la burocracia tradicional; no existen mandos intermedios ni directores de producto, ya que el propio Pavel Duróv supervisa personalmente el desarrollo de las funciones. Este enfoque permite una toma de decisiones veloz, donde un grupo reducido de ingenieros de alto nivel implementa cambios que en otras empresas requerirían meses de validación por comités.



Núcleo de Ingeniería y Desarrollo: Un grupo de aproximadamente 30 desarrolladores seleccionados mediante concursos globales, encargados del código base, la infraestructura de servidores y la seguridad del protocolo.

Liderazgo Estratégico y de Producto: Encabezado por los hermanos Durov; mientras Pavel define la visión y el diseño, Nikolai se encarga de la arquitectura técnica y el cifrado.

Operaciones y Relaciones Comerciales: Un equipo mínimo liderado por la vicepresidencia que gestiona la monetización (Telegram Premium), las asociaciones y la administración financiera.

Fuerza de Soporte de Telegram (TSF): Una red global de voluntarios que gestiona la atención al usuario y la moderación, permitiendo que la empresa mantenga una nómina oficial muy pequeña.

El modelo económico refuerza esta organización compacta al evitar la entrada de capital de riesgo tradicional. Al financiarse mediante la fortuna personal de su fundador y la emisión de bonos de deuda, la empresa no tiene una junta directiva externa a la que rendir cuentas. Esto garantiza que la estructura organizativa permanezca cerrada y centrada únicamente en la ejecución técnica y la privacidad, sin las distracciones operativas que suelen acompañar a las empresas que cotizan en bolsa.



Alcance

Normas ISO/IEC 27000

La serie **ISO/IEC 27000** (conocida comúnmente como la "familia ISO 27000") es un conjunto de estándares internacionales orientados a la seguridad de la información. Fue desarrollada de manera conjunta por la Organización Internacional de Normalización (ISO) y la Comisión Electrotécnica Internacional (IEC).

A diferencia de otras normas que se enfocan en la seguridad puramente informática (firewalls, antivirus), la familia 27000 adopta un enfoque holístico basado en la gestión del riesgo. Su objetivo principal es proteger tres principios fundamentales de la información:

- **Confidencialidad:** Garantizar que solo las personas autorizadas tengan acceso a la información.
- **Integridad:** Asegurar que la información no sea alterada de manera no autorizada o fraudulenta.
- **Disponibilidad:** Garantizar que los usuarios autorizados tengan acceso a la información cuando la requieran.

Dentro de esta familia coexisten diversos documentos: **ISO 27000** (proporciona el vocabulario y las definiciones), **ISO 27002** (una guía de buenas prácticas para implementar los controles), **ISO 27005** (especializada en la gestión de riesgos de seguridad), entre otras. Sin embargo, solo una de ellas es certificable.

Norma Seleccionada: ISO/IEC 27001:2022

Esta es la norma central de la familia porque establece los requisitos formales para diseñar, implementar, mantener y mejorar continuamente un **Sistema de Gestión de Seguridad de la Información (SGSI)**.

Cláusulas 4 a 10

Establece los requisitos del sistema de gestión bajo la estructura de alto nivel de ISO, siguiendo el ciclo de mejora continua PHVA (Planificar, Hacer, Verificar, Actuar):

- **Cláusula 4. Contexto de la organización:** Entender los factores internos y externos (en el caso de Telegram, su naturaleza distribuida y sus desafíos geopolíticos).
- **Cláusula 5. Liderazgo:** El compromiso de la alta dirección (Pavel Durov y el equipo directivo) con la seguridad.
- **Cláusula 6. Planificación:** Identificación y evaluación de riesgos, y establecimiento de objetivos de seguridad.
- **Cláusula 7. Soporte:** Recursos, competencias y concientización del equipo.
- **Cláusula 8. Operación:** Ejecución de los procesos para cumplir con la seguridad de la información.
- **Cláusula 9. Evaluación del desempeño:** Auditorías internas y revisión por la dirección.
- **Cláusula 10. Mejora:** Gestión de no conformidades y acciones correctivas.



B. El Anexo A (Los Controles de Seguridad)

La versión 2022 de la norma reestructuró los antiguos 114 controles en **93 controles**, divididos en 4 grandes temáticas. Para tu enfoque en el **procesamiento de información**, estos son los dominios aplicables:

- **Controles Organizacionales (Cláusula 5 del Anexo A):** Políticas, gestión de identidades, uso de activos.
- **Controles de Personas (Cláusula 6 del Anexo A):** Seguridad antes, durante y después del empleo (vital para el reclutamiento hermético de Telegram).
- **Controles Físicos (Cláusula 7 del Anexo A):** Seguridad en centros de datos y perímetros.
- **Controles Tecnológicos (Cláusula 8 del Anexo A):** Cifrado, desarrollo seguro, gestión de vulnerabilidades y redes.

3. Áreas y Procesos Específicos a Proteger en Telegram

Dado que el enfoque está en el **procesamiento de información**, los datos fluyen a través de procesos críticos ejecutados por un equipo sumamente pequeño. Debemos centrar la aplicación de la norma en las siguientes áreas:

Proceso A: Ciclo de Vida de Desarrollo de Software (SDLC) Seguro

- **Descripción:** Telegram actualiza sus aplicaciones móviles y de escritorio de manera sumamente veloz. El procesamiento de información comienza desde que un desarrollador escribe una línea de código.
- **Controles ISO 27001 Aplicables:**
 - **A.8.25 (Desarrollo seguro de software):** Exige reglas para el desarrollo de software seguro.
 - **A.8.28 (Gestión de la configuración):** Evita que configuraciones erróneas en el código expongan datos de los usuarios.
- **Enfoque de análisis:** Comprobar si los 30 ingenieros de Telegram (O el equipo designado a pruebas) aplican pruebas estáticas (SAST) y dinámicas (DAST) automatizadas antes de liberar actualizaciones a las tiendas de aplicaciones, mitigando el riesgo de introducir vulnerabilidades críticas en el procesamiento de mensajes.

Proceso B: Gestión de la Infraestructura y Servidores Distribuidos

- **Descripción:** El procesamiento y almacenamiento de los chats en la nube (que no son los chats secretos) se realiza en servidores repartidos por múltiples jurisdicciones.
- **Controles ISO 27001 Aplicables:**
 - **A.8.22 (Segregación de redes):** Asegura que las redes de producción estén separadas de las redes de prueba.



- **A.8.14 (Seguridad de la información durante interrupciones):**
Continuidad del procesamiento de datos en caso de caída de un nodo de red.
- **Enfoque de análisis:** Evaluar cómo Telegram fragmenta y distribuye las claves de descifrado en diferentes jurisdicciones para que ningún gobierno pueda forzar el procesamiento o entrega de datos completos.

Proceso C: Criptografía y Gestión de Claves

- **Descripción:** Telegram utiliza su protocolo propio (*MTPProto*). El procesamiento seguro de la información depende enteramente de la fortaleza de sus algoritmos y del manejo de las llaves.
- **Controles ISO 27001 Aplicables:**
 - **A.8.24 (Uso de criptografía):** Exige políticas estrictas sobre el uso de controles criptográficos y gestión de llaves.
- **Enfoque de análisis:** Analizar la gobernanza sobre la generación, almacenamiento y destrucción de las claves criptográficas que protegen la información de los usuarios tanto en tránsito como en reposo.

4. Justificación de por qué se utiliza esta norma (ISO 27001) en Telegram

La elección de la **ISO/IEC 27001** como la normativa para auditar o estructurar la seguridad en Telegram es la más adecuada por las siguientes razones justificadas:

1. Proporcionalidad y Adaptabilidad al Tamaño del Equipo

- **Justificación:** Otras normas o marcos de trabajo (como COBIT o ITIL a gran escala) requieren pesadas estructuras burocráticas, comités de aprobación y múltiples niveles de auditoría que destruirían la agilidad de los 30 ingenieros de Telegram. ISO 27001 no te dice *cómo* debes hacer las cosas obligatoriamente, sino *qué objetivos* debes cumplir. Esto permite a Telegram mantener su estructura plana y ágil, pero bajo un marco auditable y estandarizado internacionalmente.

2. Blindaje contra la Ingeniería Social y la Amenaza Interna

- **Justificación:** En una empresa pequeña con acceso masivo a infraestructura, el eslabón más débil no es el código, sino el factor humano. Si un ingeniero es coaccionado por un gobierno o sobornado, la integridad de toda la red cae. El bloque de **Controles de Personas y Gestión de Accesos** de la ISO 27001 obliga a implementar el principio de mínimo privilegio y la revisión de antecedentes, limitando el radio de impacto si uno de los pocos empleados se ve comprometido.



3. Armonización Legal Internacional (Compliance)

- **Justificación:** Al procesar información de ciudadanos de la Unión Europea, América Latina, Asia y Medio Oriente, Telegram está sujeto a marcos legales contradictorios (GDPR, leyes locales de retención de datos, etc.). Adoptar ISO 27001 como estándar base dota a la empresa de una "presunción de cumplimiento". Al estar certificada o alineada con esta norma internacional, la empresa puede demostrar a reguladores externos que sus procesos de información cumplen con las mejores prácticas globales, independientemente de dónde estén ubicados físicamente sus servidores.

4. Enfoque Basado en Riesgos para la Autonomía Financiera

- **Justificación:** Dado que Telegram no rinde cuentas a una junta directiva tradicional ni a accionistas públicos, sus decisiones de seguridad podrían volverse unilaterales o impulsivas bajo el mando de Pavel Durov. La implementación de la Cláusula 6 (Planificación y Gestión de Riesgos) de la ISO 27001 obliga a la organización a justificar las inversiones y decisiones técnicas basándose en análisis de riesgos matemáticos y lógicos, y no en meras intuiciones de producto.



Referencias normativas

Activo en Cuestión

En el marco de la ISO 27001, un activo no es solo un servidor; es "algo que tiene valor para la organización". Por lo que el activo principal para esta investigación es:

- **Activo Primario:** El **Dato del Usuario** (Mensajería, Metadatos de contacto y archivos multimedia).
- **Activos de Soporte:**
 - **Código Fuente:** El protocolo **MTProto 2.0** y las aplicaciones cliente.
 - **Infraestructura:** Servidores distribuidos y el sistema de almacenamiento fragmentado.
 - **Talento Humano:** El conocimiento crítico de los **30 ingenieros** (especialmente Nikolai Durov).

Revisión de Términos y Condiciones (T&C) vs ISO 27001

Análisis de como los T&C de Telegram se alinean con la norma:

- **Punto de T&C:** *"No utilizamos tus datos para mostrarte anuncios"* (Alineado con el control de ISO 27001 sobre **Clasificación de la Información**).
- **Punto de T&C:** *"Almacenamos los datos necesarios para que el servicio funcione"* (Alineado con el principio de **Minimización de Datos y Retención de Información** de la norma).
- **Conflicto Potencial:** Telegram declara que solo entrega datos bajo órdenes judiciales de alta sospecha de terrorismo. Bajo ISO 27001, esto debe estar procedimentado en el control de **Relación con las Autoridades**.

Activos Internos

- **Código fuente del protocolo MTProto:** El núcleo criptográfico propietario que define cómo se cifra y transfiere la información entre los clientes y los servidores.
Política funcional: **Control de Versiones y Auditoría:** Todo cambio en las librerías del núcleo criptográfico debe someterse a una revisión por pares (Peer Review) y a pruebas de estrés criptográfico antes de su despliegue.
- **Claves criptográficas privadas:** Las llaves maestras de descifrado distribuidas y fragmentadas en servidores de distintas jurisdicciones.
Política funcional: **Fragmentación Jurisdiccional:** Ninguna clave de descifrado maestra podrá ser almacenada íntegramente en un solo centro de datos o país. La reconstrucción de una clave requiere la autorización técnica de múltiples nodos en distintas jurisdicciones.
- **Bases de datos de metadatos:** Registros que contienen la información de contactos, nombres de usuario y grafos de conexión social de la plataforma.
Política funcional: **Minimización de Datos:** Solo se almacenarán los metadatos estrictamente necesarios para la funcionalidad del servicio (ej. sincronización de contactos); los registros efímeros deben ser purgados tras 24 horas.
- **Infraestructura de servidores en la nube (Nodos de almacenamiento):** Los servidores lógicos configurados y administrados por el equipo de ingeniería para el almacenamiento de los "Cloud Chats".
Política funcional: **Aislamiento de Nodos:** Cada clúster de almacenamiento debe operar de forma estanca. Un compromiso en un nodo de almacenamiento no debe permitir el escalamiento lateral hacia otros nodos de la red.
- **Código fuente de las aplicaciones cliente:** Los repositorios de código correspondientes a las versiones de iOS, Android, Desktop y Web de la plataforma.
Política funcional: **Publicación y Reproducibilidad:** Se mantendrá un repositorio público actualizado para cada plataforma (iOS, Android, Desktop), permitiendo que terceros verifiquen que el código publicado coincide exactamente con los binarios disponibles en las tiendas de aplicaciones (Reproducible Builds).
- **Talento humano especializado (Núcleo de Ingeniería):** El conocimiento técnico crítico residente en los aproximadamente 30 desarrolladores y arquitectos de software.
Política funcional: **Dispersión Geográfica y Redundancia:** El equipo de ingeniería no debe concentrarse en una sola ubicación física. Se implementará un programa de "Conocimiento Compartido" donde al menos tres ingenieros dominen cada módulo crítico para evitar puntos únicos de falla (Bus Factor).



- Documentación técnica y arquitectura de red:** Los diagramas, topologías y procedimientos internos que describen el funcionamiento y la recuperación ante desastres de la red descentralizada.
 Política funcional: **Cifrado de Documentación Sensible:** Los diagramas de topología y manuales de recuperación ante desastres (DRP) se almacenarán en contenedores cifrados con acceso restringido bajo el principio de "necesidad de saber".
- Registros de auditoría y logs de sistemas:** Los historiales de acceso, modificaciones de configuración y alertas de seguridad generados por los servidores internos.
 Política funcional: **Logs Inalterables (Write-Once):** Los registros de auditoría deben ser enviados en tiempo real a un servidor de logs centralizado y protegido contra escritura, de modo que ningún administrador pueda modificar o borrar sus propias huellas de acceso.
- Entornos de integración y despliegue continuo (CI/CD):** Las herramientas y servidores utilizados internamente para probar, compilar y liberar actualizaciones de software.
 Política funcional: **Aislamiento del Entorno de Construcción:** Los servidores de compilación deben operar en entornos efímeros y limpios, sin conexión directa a internet, para evitar la inyección de dependencias maliciosas durante el proceso de empaquetado.
- Redes de administración interna:** Las VPNs, canales encriptados y credenciales de acceso utilizadas por el equipo de desarrollo para gestionar la infraestructura global.
 Política funcional: **Autenticación Multifactor de Hardware (MFA):** El acceso a las VPNs y canales de administración interna requerirá obligatoriamente el uso de llaves físicas de seguridad (tokens de hardware), eliminando la dependencia exclusiva de contraseñas.
- Red Blockchain:** La red blockchain desarrollada por telegram para la transferencia de criptomonedas bajo su propio protocolo.
 Política funcional: **Gobernanza y Consenso Distribuido:** Se implementará un protocolo de consenso que impida la concentración de poder de cómputo o de participación (Staking) en una sola jurisdicción geográfica o entidad legal, asegurando que la red permanezca operativa incluso si nodos críticos son desconectados.



Activos Externos:

- **Infraestructura física de centros de datos de terceros:** Los proveedores que suministran el espacio físico, enfriamiento y energía eléctrica para alojar los servidores de Telegram en diversas regiones.
Política funcional: **Aislamiento de Hardware (Bare Metal):** Se priorizará el uso de servidores físicos dedicados sobre instancias virtuales para evitar ataques de canal lateral. Los discos duros deben contar con cifrado de hardware total (SED) que impida la lectura de datos si el disco es extraído físicamente.
- **Plataformas de distribución de software:** Las tiendas de aplicaciones (Apple App Store, Google Play Store, Microsoft Store) necesarias para la entrega de actualizaciones a los usuarios finales.
Política funcional: **Diversificación de Canales:** Además de las tiendas oficiales, se mantendrán versiones de instalación directa (APKs) y versiones web independientes para garantizar el acceso en caso de retiro arbitrario de las tiendas de Apple o Google.
- **Dispositivos finales de los usuarios (Endpoints):** Los teléfonos inteligentes, tabletas y computadoras personales donde reside temporalmente o permanentemente la información descifrada (ej. Secret Chats).
Política funcional: **Higiene de Datos Local:** La aplicación implementará por defecto el borrado de caché sensible y la opción de "Autodestrucción de mensajes" para reducir la huella forense en el almacenamiento físico del dispositivo.
- **Proveedores de pasarelas de SMS (OTP):** Las empresas de telecomunicaciones de terceros contratadas para el envío masivo de códigos de verificación durante el registro o inicio de sesión.
Política funcional: **Transición a Verificación Interna:** Se priorizará el envío de códigos de acceso a través de dispositivos ya vinculados. El SMS se considerará un método de última instancia con caducidad ultra-corta (menor a 2 minutos).
- **Redes de proveedores de servicios de internet (ISPs):** La infraestructura global de telecomunicaciones que permite el enrutamiento del tráfico entre los usuarios y los servidores de la aplicación.
Política funcional: **Resiliencia de Red (Domain Fronting/Proxies):** La infraestructura debe soportar el uso de protocolos de ofuscación de tráfico y sistemas de proxies inteligentes (MTProto Proxy) para evadir la censura por parte de los ISPs.



- Pasarelas de pago de terceros:** Los procesadores financieros (como Stripe, Google Pay o Apple Pay) utilizados para gestionar las suscripciones de Telegram Premium y la compra de activos digitales.
 Política funcional: **Tokenización de Pagos:** La plataforma no almacenará números de tarjetas de crédito; toda transacción se manejará mediante tokens proporcionados por el procesador, asegurando que un compromiso en la base de datos de Telegram no exponga datos financieros.
- Servicios de mitigación de ataques DDoS:** Los proveedores externos de filtrado de tráfico utilizados para absorber y repeler ataques de denegación de servicio a gran escala.
 Política funcional: **Filtrado de Capa de Transporte (Capa 4):** La mitigación se limitará preferentemente a las capas de red y transporte para bloquear tráfico malicioso basado en volumen, evitando la inspección de la capa de aplicación (Capa 7) siempre que sea técnicamente viable.
- Proveedores de servicios de nombres de dominio (DNS):** Las entidades responsables de la resolución de los dominios oficiales de la empresa, vitales para que los clientes encuentren los servidores.
 Política funcional: **Implementación de DNSSEC y Bloqueo de Registro:** Todos los dominios críticos deben contar con extensiones de seguridad (DNSSEC) para prevenir el envenenamiento de caché y "Registry Lock" para evitar transferencias o cambios de DNS no autorizados mediante ingeniería social.
- Red de voluntarios de soporte (Telegram Support Force - TSF):** El personal externo y descentralizado que asiste en la moderación y atención a usuarios, quienes manejan información de soporte sin ser empleados directos.
 Política funcional: **Acceso Compartimentado y Anonimizado:** Los voluntarios accederán a herramientas de soporte que oculten datos sensibles (como números de teléfono completos o direcciones IP) mediante máscaras de datos, mostrando solo lo estrictamente necesario para resolver la duda técnica.
- Redes de entrega de contenido (CDN) descentralizadas:** Infraestructura externa utilizada de apoyo en regiones específicas para acelerar la descarga de archivos multimedia públicos y reducir la latencia.
 Política funcional: **Exclusión de Contenido Privado:** Solo se permitirá el almacenamiento en caché de archivos multimedia públicos (canales públicos, fotos de perfil públicas) en nodos de CDN externos; los mensajes de chats privados y grupos cerrados nunca deberán tocar servidores de CDN de terceros.



Términos y Definiciones de la ISO 27000 (Aplicables a Telegram)

De las ~81 definiciones, no necesitas todas. Para Telegram, estas son las más críticas que deberías incluir en tu reporte:

1. **Información (2.37):** Datos que tienen valor para la organización.
2. **Seguridad de la Información (2.28):** Preservación de la confidencialidad, integridad y disponibilidad.
3. **Sistema de Gestión de Seguridad de la Información (SGSI) (2.30):** Parte del sistema de gestión general basada en un enfoque de riesgo empresarial.
4. **Riesgo (2.61):** Efecto de la incertidumbre sobre los objetivos.
5. **Activo (2.4):** Algo que tiene valor para la organización.
6. **Confidencialidad (2.12):** Propiedad de que la información no se ponga a disposición de personas no autorizadas.
7. **Integridad (2.40):** Propiedad de exactitud y completitud.
8. **Disponibilidad (2.9):** Propiedad de ser accesible y utilizable a petición de una entidad autorizada.
9. **Control (2.16):** Medida que modifica el riesgo.
10. **Amenaza (2.77):** Causa potencial de un incidente no deseado.

SECCIÓN 6: PLANIFICACION

Matriz de riesgos

01 – INSIGNIFICANTE.	02 – MENOR.	03 – SIGNIFICATIVO.	04 – MAYOR.	05 – SEVERO.	
05 (medio)	10 (alto)	15 (muy alto)	20 (extremo)	25 (extremo)	05 – CASI SEGURO.
04 (medio)	08 (medio)	12 (alto)	16 (muy alto)	20 (extremo)	04 – PROBABLE.
03 (bajo)	06 (medio)	09 (medio)	12 (alto)	15 (muy alto)	03 – MODERADO.
02 (muy bajo)	04 (bajo)	06 (medio)	08 (medio)	10 (alto)	02 – POCO PROBABLE.
01 (muy bajo)	02 (muy bajo)	03 (bajo)	04 (medio)	05 (medio)	01 – RARO.

I. Riesgo Extremo (16 - 25)

Riesgos que requieren atención inmediata y controles estrictos.

1. **Claves Criptográficas Privadas**
 - a. **Riesgo:** Pérdida de confidencialidad total de los datos.
 - b. **Matriz:** Probabilidad (04) x Impacto (05) = **Extremo (20)**.
 - c. **Política:** Fragmentación jurisdiccional y almacenamiento exclusivo en HSM.
2. **Infraestructura de Servidores (Nodos)**
 - a. **Riesgo:** Acceso no autorizado a "Cloud Chats".
 - b. **Matriz:** Probabilidad (04) x Impacto (05) = **Extremo (20)**.



- c. **Política:** Aislamiento de nodos y cifrado de datos particionado.
- 3. **Talento Humano (Núcleo de Ingeniería)**
 - a. **Riesgo:** Fuga de conocimiento crítico o "Bus Factor".
 - b. **Matriz:** Probabilidad (04) x Impacto (04) = **Extremo (16)**.
 - c. **Política:** Dispersión geográfica y protocolos de salida segura.
- 4. **Mitigación de ataques DDoS**
 - a. **Riesgo:** Caída sistémica de la plataforma por saturación.
 - b. **Matriz:** Probabilidad (05) x Impacto (05) = **Extremo (25)**.
 - c. **Política:** Filtrado en Capa 4 y redundancia con múltiples proveedores Anycast.
- 5. **Redes de Administración Interna**
 - a. **Riesgo:** Movimiento lateral de atacantes hacia el núcleo.
 - b. **Matriz:** Probabilidad (04) x Impacto (05) = **Extremo (20)**.
 - c. **Política:** Acceso mediante Zero Trust y llaves físicas (MFA).
- 6. **Código Fuente del Protocolo MTProto**
 - a. **Riesgo:** Descubrimiento de vulnerabilidades críticas por ingeniería inversa.
 - b. **Matriz:** Probabilidad (03) x Impacto (05) = **Muy Alto / Extremo (15-20)**.
 - c. **Política:** Auditorías criptográficas constantes y control estricto de repositorios.

II. Riesgo Muy Alto (10 - 15)

Riesgos con impacto severo que pueden comprometer la operación.

- 7. **Proveedores de Pasarelas de SMS (OTP)**
 - a. **Riesgo:** Interceptación de códigos (SS7) para secuestro de cuentas.
 - b. **Matriz:** Probabilidad (05) x Impacto (03) = **Muy Alto (15)**.
 - c. **Política:** Priorizar verificación interna y rotación de proveedores.
- 8. **Red Blockchain**
 - a. **Riesgo:** Fallo en contratos inteligentes o pérdida de activos.
 - b. **Matriz:** Probabilidad (03) x Impacto (04) = **Alto (12)**.
 - c. **Política:** Auditoría matemática de TVM y nodos descentralizados.
- 9. **Bases de Datos de Metadatos**
 - a. **Riesgo:** Perfilamiento de usuarios por filtración de grafos sociales.
 - b. **Matriz:** Probabilidad (04) x Impacto (03) = **Alto (12)**.
 - c. **Política:** Cifrado en reposo y purga de logs efímeros.
- 10. **Proveedores de DNS**
 - a. **Riesgo:** Redirección de tráfico mediante secuestro de dominios.
 - b. **Matriz:** Probabilidad (03) x Impacto (05) = **Muy Alto (15)**.
 - c. **Política:** Implementación obligatoria de DNSSEC y Registry Lock.
- 11. **Documentación Técnica y Arquitectura**
 - a. **Riesgo:** Manual de instrucciones para un atacante externo.
 - b. **Matriz:** Probabilidad (02) x Impacto (05) = **Alto (10)**.
 - c. **Política:** Cifrado de documentos y acceso por necesidad de saber.



12. Entornos CI/CD

- a. **Riesgo:** Inyección de malware en las actualizaciones oficiales.
- b. **Matriz:** Probabilidad (03) x Impacto (05) = **Muy Alto (15)**.
- c. **Política:** Firma de código multi-etapa y aislamiento de compilación.

III. Riesgo Medio / Bajo (04 - 09)

Riesgos operacionales manejables con controles preventivos.

13. Código Fuente de Aplicaciones Cliente

- a. **Riesgo:** Creación de clones maliciosos de la app.
- b. **Matriz:** Probabilidad (04) x Impacto (02) = **Medio (08)**.
- c. **Política:** Repositorios públicos y Reproducible Builds para validación.

14. Registros de Auditoría (Logs)

- a. **Riesgo:** Manipulación de huellas tras una intrusión.
- b. **Matriz:** Probabilidad (03) x Impacto (03) = **Medio (09)**.
- c. **Política:** Logs inalterables (Write-Once) y monitoreo de anomalías.

15. Infraestructura de Centros de Datos (Terceros)

- a. **Riesgo:** Acceso físico al hardware por personal del hosting.
- b. **Matriz:** Probabilidad (02) x Impacto (04) = **Medio (08)**.
- c. **Política:** Servidores Bare Metal con cifrado de disco total (SED).

16. Dispositivos Finales de Usuarios (Endpoints)

- a. **Riesgo:** Acceso local por robo del teléfono o malware.
- b. **Matriz:** Probabilidad (05) x Impacto (01) = **Medio (05)**.
- c. **Política:** Autodestrucción de mensajes y borrado de caché local.

17. Plataformas de Distribución (App Stores)

- a. **Riesgo:** Eliminación de la app por censura gubernamental.
- b. **Matriz:** Probabilidad (03) x Impacto (03) = **Medio (09)**.
- c. **Política:** Canales de distribución alternativos (APK, Web).

18. Redes de ISPs

- a. **Riesgo:** Bloqueo regional o inspección profunda de paquetes.



- b. **Matriz:** Probabilidad (04) x Impacto (02) = **Medio (08)**.
- c. **Política:** Protocolos de ofuscación y sistemas de proxy (MTProto).

19. Pasarelas de Pago de Terceros

- a. **Riesgo:** Exposición de datos de facturación de usuarios.
- b. **Matriz:** Probabilidad (02) x Impacto (03) = **Bajo (06)**.
- c. **Política:** Tokenización total y separación de identidad financiera.

20. Redes CDN Descentralizadas

- a. **Riesgo:** Caché de contenido manipulado.
- b. **Matriz:** Probabilidad (02) x Impacto (02) = **Bajo (04)**.
- c. **Política:** Exclusividad de contenido público y verificación de hashes.

Definir la Ley dentro del Marco de Referencia

Telegram opera en un "limbo" legal estratégico, definición del marco legal que aplica según su operación:

- **GDPR (Reglamento General de Protección de Datos - UE):** Obligatorio porque procesan datos de ciudadanos europeos. La ISO 27001 es el mejor vehículo para demostrar cumplimiento con el GDPR.
- **Ley Federal de los EAU (No. 2 de 2019):** Al estar su sede operativa en Dubái, deben cumplir con las leyes de protección de datos de salud y telecomunicaciones de los Emiratos Árabes Unidos.
- **Leyes de Privacidad de las Islas Vírgenes Británicas:** Donde está registrada la entidad legal principal, regulando su gobernanza corporativa.
- **Ciberseguridad:** Normativas internacionales de lucha contra el cibercrimen que obligan a la cooperación limitada (aunque Telegram es famoso por su resistencia en este punto).



SECCIÓN 7: SOPORTE

CARTA DE CONFORMIDAD Y NOTIFICACIÓN DE SEGURIDAD (PSI)

DEPARTAMENTO: Ciberseguridad e Infraestructura – Telegram FZ-LLC

CÓDIGO DE DOCUMENTO: TLG-SEC-POL-2026

1. DATOS DEL COLABORADOR

- **Nombre completo:** _____
- **Puesto / Área:** _____
- **ID de Empleado:** _____ **Fecha:** _____

2. GESTIÓN DE COMPETENCIA Y RECURSOS

En cumplimiento con la gestión de recursos de la organización, se ha determinado lo siguiente:

- Se han definido los conocimientos y competencias necesarios para su puesto, determinando que la apertura de puertos de red no esenciales no forma parte de sus herramientas requeridas para la operación diaria.
- El entorno de materiales e infraestructura (su computadora) ha sido configurado bajo el estándar de "**Menor Privilegio**".

3. CONCIENCIACIÓN DEL SGSI Y PSI

El colaborador declara ser consciente de los lineamientos del **Sistema de Gestión de Seguridad de la Información (SGSI)** de Telegram:

- **Protección de Activos:** Entiendo que el cierre de puertos lógicos es una medida de protección para la información valiosa de la empresa y reduce la superficie de ataque ante posibles intrusiones o malware.
- **Aceptación de Políticas:** Reconozco que los puertos de mi equipo de trabajo han sido cerrados/bloqueados preventivamente como parte de la **Política de Seguridad de la Información (PSI)** vigente.

4. PROTOCOLO DE COMUNICACIÓN

Se establecen los procesos de comunicación oficiales para cualquier solicitud técnica:

- **Qué comunicar:** Cualquier necesidad operativa que requiera una excepción en el firewall.



- **Canal:** Las solicitudes deberán enviarse vía ticket al equipo de Seguridad Informática, incluyendo la justificación técnica.
- **Evaluación:** El equipo de InfoSec evaluará si el usuario posee la competencia y la necesidad real para autorizar dicha excepción de forma temporal.

5. DECLARACIÓN DE CONFORMIDAD

Al firmar este documento, el colaborador acepta que ha sido notificado sobre las restricciones de red en su equipo y se compromete a no intentar vulnerar o modificar la configuración de seguridad establecida por el departamento de IT.

"Entiendo que estas medidas no son una limitante a mi trabajo, sino una responsabilidad compartida para proteger la infraestructura global de Telegram."

Firma del Trabajador	Sello / Firma de Seguridad Informática
Nombre:	Telegram Team

TELEGRAM

Sistema de Gestión de Seguridad de la Información

Informe de Diagnóstico · ISO/IEC 27001:2022

Equipo de Ciberseguridad · Mayo 2026

Confidencial — Solo para uso interno de Telegram FZ-LLC



¿Quiénes somos y por qué estamos aquí?



+1,000 M

Usuarios activos
globales



ISO 27001

Marco normativo
seleccionado



30 Ing.

Núcleo técnico
de Telegram

Contexto del Proyecto

- Telegram fue fundada en 2013 por Pável y Nikolái Dúrov como plataforma de mensajería cifrada.
- Opera con estructura plana (~30 ingenieros) sin burocracia tradicional, liderada directamente por Pavel Durov.
- Nuestra labor: diseñar e implementar un SGSI bajo ISO/IEC 27001:2022 para proteger los activos críticos de la organización.

Telegram



Marco Normativo: ISO/IEC 27001:2022

Cláusulas Clave del SGSI

4	Contexto Factores geopolíticos y estructura distribuida
5	Liderazgo Compromiso de Pavel y Nikolai Durov
6	Planificación Gestión de riesgos matemática y objetivos
8	Operación Ejecución de procesos de seguridad
9-10	Evaluación / Mejora Auditorías internas y acciones correctivas

4 Dominios del Anexo A (93 controles)

Org. Controles Organizacionales	Pers. Controles de Personas
Fís. Controles Físicos	Tec. Controles Tecnológicos

✓ ISO 27001 fue elegida por su adaptabilidad a estructuras planas, enfoque en riesgo y reconocimiento internacional para compliance GDPR.

Activos & Procesos Críticos Identificados

ACTIVO PRIMARIO:

Dato del Usuario — Mensajes, metadatos de contacto y archivos multimedia



Proceso A

SDLC Seguro

A.8.25 · A.8.28

Pruebas SAST/DAST en cada actualización. Los 30 ingenieros aplican revisión por pares antes del despliegue.



Proceso B

Infraestructura Distribuida

A.8.22 · A.8.14

Claves fragmentadas en múltiples jurisdicciones. Ningún gobierno puede forzar entrega de datos completos.



Proceso C

Criptografía & Gestión de Claves

A.8.24

Protocolo MTProto 2.0. Fragmentación jurisdiccional de claves maestras. Ningún nodo almacena la clave completa.



Políticas Funcionales Definidas



Fragmentación Jurisdiccional

Ninguna clave maestra completa en un solo país o nodo.



Reproducible Builds

El código público debe coincidir bit a bit con los binarios en tiendas.



Minimización de Datos

Metadatos purgados a las 24 h si son efímeros.



MFA de Hardware

VPNs y administración solo con llaves físicas (tokens), no contraseñas.



Aislamiento de Nodos

Compromiso en un nodo no permite escalamiento lateral.



Aislamiento CI/CD

Entornos de compilación efímeros sin acceso a internet.



Logs Inalterables (Write-Once)

Registros enviados a servidor centralizado protegido contra escritura.



Tokenización de Pagos

Telegram no almacena datos de tarjetas; solo tokens del procesador.

Marco Legal Aplicable: GDPR (UE) · Ley EAU No. 2/2019 · Islas Vírgenes Británicas · Ciberseguridad Internacional



Siguiente Paso: Carta de Conformidad PSI

Documento TLG-SEC-POL-2026 · Departamento de Ciberseguridad e Infraestructura

1

Datos del Colaborador

Nombre, puesto, ID y fecha de firma.

2

Gestión de Competencias

Confirma configuración bajo principio de mínimo privilegio.

3

Concienciación del SGSI

Acepta cierre de puertos como medida de protección oficial.

4

Protocolo de Comunicación

Excepciones al firewall solo via ticket con justificación técnica.



Declaración de Conformidad: Al firmar, el colaborador reconoce las restricciones de red y se compromete a no vulnerar la configuración de seguridad. Esta carta será custodiada por el Departamento de Ciberseguridad.

Telegram



Sistema de Gestión de Seguridad de la Información

SECCIÓN 9 — EVALUACIÓN DEL DESEMPEÑO

Cláusulas 9.1 · 9.2 · 9.3 | ISO/IEC 27001:2022 | Incluye: Diagnóstico de Cumplimiento

Código de documento: TLG-SGSI-SEC9-2026 | Departamento de Ciberseguridad

Mayo 2026

Introducción

La Sección 9 de la norma ISO/IEC 27001:2022 corresponde a la fase 'Verificar' del ciclo PHVA. Su propósito es demostrar, mediante evidencia objetiva, que el SGSI de Telegram FZ-LLC funciona conforme a lo planificado, cumple los requisitos de la norma y mejora continuamente. Este documento incluye el diagnóstico de cumplimiento de cada criterio evaluado.

Esta sección se divide en tres componentes:

- 9.1 Seguimiento, medición, análisis y evaluación.
- 9.2 Auditoría interna.
- 9.3 Revisión por la dirección.

Escala de Evaluación de Cumplimiento:

✓ CUMPLE (2 pts): El criterio está documentado e implementado con evidencia disponible. ① CUMPLE PARCIALMENTE (1 pt): El criterio existe en concepto o política, pero carece de implementación formal o documentación completa. ✗ NO CUMPLE (0 pts): El criterio no está implementado ni documentado.

Fuente de referencia:

Los lineamientos presentados han sido tomados de ISMS.online (www.isms.online), plataforma internacional especializada en ISO/IEC 27001, y adaptados al contexto de Telegram FZ-LLC.

9.1 Seguimiento, Medición, Análisis y Evaluación

La cláusula 9.1 exige que Telegram determine qué monitorear, con qué métodos, cuándo y quién lo hace, generando datos válidos y reproducibles para evaluar la eficacia de los controles. Según ISMS.online, no es necesario medirlo todo: las métricas deben ser



significativas, alineadas con los objetivos del SGSI (cláusula 6.2) y usadas para tomar decisiones.

9.1.1 Determinación de Qué Monitorear [Criterio 9.1(a)]

Telegram debe identificar los procesos, controles y objetivos del SGSI que serán objeto de seguimiento. Esto incluye los tres procesos críticos identificados: SDLC seguro, infraestructura distribuida y criptografía/MTPROTO.

✓ CUMPLE	Evidencia / Justificación: Telegram define explícitamente KPIs para sus procesos críticos: número de incidentes, disponibilidad de nodos ($\geq 99.9\%$), vulnerabilidades en SDLC, integridad de claves MTPROTO y cumplimiento de la PSI. Todos están alineados con los activos primarios identificados en el documento de alcance.
-----------------	--

9.1.2 Métodos de Medición Válidos y Reproducibles [Criterio 9.1(b)]

Los métodos empleados deben garantizar que los resultados sean comparables y reproducibles a lo largo del tiempo, permitiendo identificar tendencias significativas.

⚠ CUMPLE PARCIALMENTE	Evidencia / Justificación: Existen dashboards técnicos internos y herramientas SAST/DAST, sin embargo no se ha formalizado en un procedimiento documentado la metodología de validación de cada método de medición. El riesgo es que, ante una auditoría de certificación, el equipo no pueda demostrar reproducibilidad formal.
------------------------------	--

9.1.3 Frecuencia de Monitoreo Definida [Criterio 9.1(c)]

La organización debe establecer cuándo se realizarán el seguimiento y la medición de cada KPI, asegurando cadencias apropiadas al nivel de riesgo de cada área.

✓ CUMPLE	Evidencia / Justificación: Cada KPI tiene una frecuencia asignada y justificada: monitoreo mensual para disponibilidad de nodos, trimestral para incidentes, semestral para criptografía, y por cada release para vulnerabilidades de SDLC. Las frecuencias están calibradas al nivel de riesgo de cada proceso.
-----------------	--



9.1.4 KPIs de Telegram — Marco de Medición

A continuación se presenta el marco completo de indicadores de desempeño propuesto, con su estado actual de implementación:

Indicador (KPI)	Descripción / Métrica	Frecuencia	Estado
Incidentes de seguridad	N° confirmados por trimestre, por severidad	Trimestral	Implementado
Tiempo de resolución	Horas promedio desde detección hasta cierre	Mensual	Implementado
Cobertura de capacitación	% del personal que completó formación SGSI/PSI	Semestral	En desarrollo
Vulnerabilidades en SDLC	N° críticos detectados en SAST/DAST antes del deploy	Por release	Implementado
Disponibilidad de nodos	% uptime de nodos distribuidos (objetivo ≥99.9%)	Mensual	Implementado
Integridad de claves MTPROTO	Auditorías de fragmentación sin hallazgos críticos	Semestral	En desarrollo
Cumplimiento PSI	% colaboradores con Carta TLG-SEC-POL-2026 firmada	Anual	En desarrollo
Resultados de auditorías internas	N° no conformidades y % cerradas en plazo	Por ciclo	Pendiente

9.1.5 Responsables de Medición y Análisis [Criterios 9.1(d), 9.1(e), 9.1(f)]

La norma exige que se identifique formalmente quién realiza cada medición (d), cuándo se analizan los resultados (e) y quién los analiza (f).

✓ CUMPLE	Evidencia / Justificación: Criterio (e): Los ciclos de análisis están definidos y alineados con la frecuencia de cada KPI, lo que garantiza que los datos se revisen oportunamente.
----------	---

❶ CUMPLE PARCIALMENTE	Evidencia / Justificación: Criterio (d): El equipo de ciberseguridad está implícitamente responsabilizado de las mediciones, pero no existe un documento formal que asigne responsabilidades nominales por KPI. Se recomienda crear una Matriz RACI para la gestión de métricas.
-----------------------	--



X NO CUMPLE

Evidencia / Justificación:

Criterio (f): No existe una política o procedimiento documentado que designe formalmente a los responsables del análisis y evaluación de resultados. La estructura organizacional plana de Telegram no ha formalizado este rol de manera explícita, lo que representa un riesgo ante una auditoría de certificación.

Nota ISMS.online — Error común:

"A common pitfall is defining too few metrics or irrelevant ones — this can lead to non-conformities. Focus on areas of higher risk. Data should surface issues before an incident or auditor does, not after."

9.2 Auditoría Interna

La cláusula 9.2 establece que Telegram debe llevar a cabo auditorías internas del SGSI a intervalos planificados para verificar que el sistema cumple tanto con los requisitos propios de la organización como con los de la norma. ISMS.online define este proceso como una 'forensic self-assessment': encontrar las propias no conformidades antes que el auditor externo.

9.2.1 Programa de Auditoría Planificado [Criterio 9.2.1]

La subcláusula 9.2.2 exige que Telegram planifique, establezca, implemente y mantenga un programa de auditoría que defina frecuencia, métodos, responsabilidades y criterios.

**🕒 CUMPLE
PARCIALMENTE**

Evidencia / Justificación:

Se ha propuesto un calendario de auditorías estructurado por área de riesgo, cubriendo los 7 procesos críticos del SGSI. Sin embargo, este programa aún no ha sido formalmente aprobado y publicado por la Alta Dirección, ni existe un documento oficial del 'Programa Anual de Auditoría Interna 2026' con firmas de autorización.

9.2.2 Criterios, Alcance y Métodos [Criterio 9.2.2]

Cada auditoría debe tener criterios definidos, alcance delimitado y métodos especificados para garantizar resultados objetivos.

✓ CUMPLE

Evidencia / Justificación:



	Cada auditoría del programa tiene criterios ISO (A.8.25, A.8.24, A.8.22, etc.) y políticas funcionales asociadas. Los métodos están definidos: revisión documental, entrevistas con ingenieros y pruebas técnicas mediante muestreo. El alcance es basado en riesgo, con mayor frecuencia para procesos críticos como MTPROTO y CI/CD.
--	--

Área / Proceso	Criterios de Auditoría	Responsable Auditor	Frecuencia	Estado
SDLC y Desarrollo Seguro	A.8.25 · A.8.28 · SAST/DAST	Auditor externo	Semestral	Planificado Q2 2026
Infraestructura Distribuida	A.8.22 · A.8.14 · Aislamiento de Nodos	Auditoría cruzada	Anual	Planificado Q3 2026
Criptografía MTPROTO	A.8.24 · Fragmentación Jurisdiccional	Auditor externo esp.	Semestral	Planificado Q2/Q4
Gestión de Accesos y MFA	A.8 Controles · MFA Hardware · Min. Privilegio	Auditor interno ind.	Anual	Planificado Q3 2026
Logs y Registros (Write-Once)	Política Write-Once · Integridad de logs	Auditoría cruzada	Anual	Planificado Q4 2026
Cumplimiento PSI	TLG-SEC-POL-2026 · Cláusula 7	RRHH + InfoSec	Anual	Planificado Q1 2027
Entornos CI/CD	Aislamiento · Reproducible Builds	Auditor externo	Anual	Planificado Q4 2026

9.2.3 Independencia e Imparcialidad del Auditor [Criterio 9.2.3]

La norma prohíbe que el auditor evalúe áreas en las que tiene participación directa. Este es uno de los puntos de mayor no conformidad en organizaciones pequeñas.

❶ CUMPLE PARCIALMENTE	Evidencia / Justificación: El principio de independencia está establecido en el programa, y se contempla el uso de auditores externos especializados para los procesos más críticos (MTPROTO, CI/CD, SDLC). Sin embargo, Telegram no cuenta formalmente con un equipo de auditoría interna separado del equipo de ingeniería. Para procesos de menor riesgo, se plantea 'auditoría cruzada' entre ingenieros, lo cual puede comprometer la objetividad requerida por la norma.
------------------------------	--



9.2.4 Comunicación de Resultados a la Dirección [Criterio 9.2.4]

Los resultados de las auditorías deben ser reportados formalmente a la gestión relevante, sirviendo de insumo para la revisión por la dirección (9.3).

✓ CUMPLE	Evidencia / Justificación: El flujo de auditoría establece que todos los hallazgos y no conformidades son comunicados formalmente a Pavel Durov (CEO) y Nikolai Durov (CTO), quienes son los responsables estratégicos del SGSI. Esta comunicación alimenta directamente la revisión por la dirección de la cláusula 9.3.
----------	---

9.2.5 Documentación del Programa y Resultados [Criterio 9.2.5]

La norma exige que se conserve información documentada tanto del programa de auditoría como de los resultados individuales de cada auditoría ejecutada.

X NO CUMPLE	Evidencia / Justificación: No existe aún un repositorio centralizado y formalmente protegido para la documentación de evidencias de auditoría. Aunque la Política de Logs Inalterables (Write-Once) está definida como objetivo, su implementación técnica no ha sido completada ni verificada. Este es un punto crítico que generaría una No Conformidad Mayor en una auditoría de certificación.
-------------	--

Principio ISMS.online:

"You cannot be the Judge and the Defendant. The most common Major Non-Conformance in Clause 9.2 is the IT Manager auditing the IT Department. If you do not have a separate audit team, you must outsource the internal audit."

9.3 Revisión por la Dirección

La cláusula 9.3 requiere que la Alta Dirección — Pavel Durov (CEO), Nikolai Durov (CTO) e Ilya Perekopsky (VP Operaciones) — revise el SGSI a intervalos planificados para asegurar su conveniencia, adecuación y eficacia continua, tomando decisiones estratégicas con base en evidencia.



9.3.1 Revisión Periódica Planificada [Criterio 9.3.1]

La norma exige que la revisión ocurra a intervalos planificados, con fechas definidas y participación de la Alta Dirección. Telegram debe demostrar que estas revisiones se realizan y se documentan.

❶ CUMPLE PARCIALMENTE	Evidencia / Justificación: Se ha propuesto una cadencia de revisión estructurada (anual completa + seguimiento trimestral + revisiones extraordinarias). Sin embargo, no existe aún un calendario formal con fechas fijas aprobado y publicado. La Alta Dirección no ha convocado formalmente ninguna revisión bajo el SGSI. Esto es insuficiente para demostrar cumplimiento ante un auditor externo.
------------------------------	--

9.3.2 Entradas Obligatorias de la Revisión [Criterio 9.3.2]

La subcláusula 9.3.2 define los elementos de entrada mínimos que deben ser considerados en cada revisión: acciones previas, cambios de contexto, KPIs, resultados de auditorías, riesgos, retroalimentación de partes interesadas y oportunidades de mejora.

✓ CUMPLE	Evidencia / Justificación: Todos los elementos de entrada exigidos por la norma están incluidos y mapeados en la tabla de revisión por la dirección. Se contempla el análisis de cambios en GDPR, Ley EAU No. 2/2019, cambios en el equipo técnico, resultados de KPIs, hallazgos de auditorías, estado del registro de riesgos y retroalimentación de usuarios y reguladores.
-----------------	--

Elemento de Entrada	Hallazgos en Telegram	Decisión / Acción
Estado de acciones previas	Cierre de no conformidades del ciclo anterior. Revisión de la Carta PSI TLG-SEC-POL-2026.	Confirmar acciones cerradas; reasignar pendientes.
Cambios en contexto externo	Actualizaciones al GDPR, cambios en Ley EAU No. 2/2019, nuevos bloqueos por ISPs.	Actualizar cláusula 4; ajustar controles afectados.
Cambios en contexto interno	Cambios en el equipo de ingeniería; cumplimiento del programa de dispersión geográfica del talento.	Actualizar inventario de competencias; revisar Bus Factor.
Resultados de KPIs (9.1)	Tendencias: incidentes, disponibilidad de nodos, vulnerabilidades cerradas antes del despliegue.	Ajustar objetivos o asignar recursos adicionales.



Resultados de auditorías (9.2)	Hallazgos del programa anual: no conformidades en gestión de claves, CI/CD y cumplimiento PSI.	Aprobar plan de acciones correctivas (cláusula 10).
Estado de riesgos	Revisión del registro de riesgos: MTPProto, infraestructura distribuida, talento humano clave.	Actualizar plan de tratamiento; validar controles.
Retroalimentación stakeholders	Reportes de usuarios, requerimientos legales, feedback del equipo técnico interno.	Incorporar ajustes al SGSI si se detectan brechas.
Oportunidades de mejora	Automatización de monitoreo de logs, mejora de herramientas SAST/DAST, expansión de nodos.	Incluir en plan de mejora continua (cláusula 10.2).

9.3.3 Salidas Documentadas de la Revisión [Criterio 9.3.3]

Las decisiones tomadas en la revisión — mejoras, cambios al SGSI y necesidades de recursos — deben quedar formalmente documentadas en actas u otro medio oficial.

❶ CUMPLE PARCIALMENTE	Evidencia / Justificación: Las categorías de decisión y salidas obligatorias están definidas y alineadas con la norma. Sin embargo, no existe aún una plantilla oficial de acta de revisión por la dirección formalmente adoptada por Telegram, ni evidencia de que haya sido aplicada. Se recomienda diseñar y aprobar la plantilla antes de la primera revisión formal.
------------------------------	---

9.3.4 Alineación con Objetivos Estratégicos [Criterio 9.3.4]

La revisión debe asegurar que el SGSI permanece alineado con la dirección estratégica de Telegram y con su misión de privacidad y libertad de comunicación global.

✓ CUMPLE	Evidencia / Justificación: La revisión contempla explícitamente la verificación de que el SGSI apoya la misión de Telegram: garantizar el derecho a la privacidad y la libre comunicación global. Los KPIs de disponibilidad de nodos y criptografía MTPProto están directamente ligados a esta misión, y la revisión incluye el análisis de cómo los cambios regulatorios externos pueden afectar la autonomía operativa de la plataforma.
-----------------	---

Requisito ISMS.online:



"Lock in the Management Review dates. Ensure the agenda covers every mandatory input. If the Board skips a meeting, you are non-compliant. The auditor will check evidence of these reviews during certification."

Resumen de Cumplimiento — Sección 9

A continuación se presenta el diagnóstico consolidado de los 15 criterios evaluados en la Sección 9, con su estado de cumplimiento, puntuación y calificación final del SGSI de Telegram FZ-LLC.

Tabla Consolidada de Criterios

N°	Subcláusula / Criterio	Estado	Observación Clave
1	9.1(a) — Definición de qué monitorear	CUMPLE	Telegram define explícitamente KPIs para MTPProto, SDLC, nodos e incidentes.
2	9.1(b) — Métodos de medición válidos y reproducibles	CUMPLE PARCIALMENTE	Existen dashboards técnicos internos, pero no se ha formalizado un procedimiento documentado de validación de métodos.
3	9.1(c) — Frecuencia de monitoreo definida	CUMPLE	Cada KPI tiene frecuencia asignada (mensual, trimestral, semestral, por release).
4	9.1(d) — Responsables de realizar la medición	CUMPLE PARCIALMENTE	El equipo de ciberseguridad está implícitamente responsabilizado, pero no existe un documento formal que asigne responsabilidades nominales por KPI.
5	9.1(e) — Frecuencia de análisis definida	CUMPLE	Los ciclos de análisis están alineados con la frecuencia de cada KPI.
6	9.1(f) — Responsables del análisis y evaluación	NO CUMPLE	No existe una política documentada que designe formalmente a los responsables del análisis de resultados. La estructura



			plana de Telegram no ha formalizado este rol.
7	9.2.1 — Programa de auditoría planificado	CUMPLE PARCIALMENTE	Se propone un calendario de auditorías por área de riesgo, pero aún no ha sido formalmente aprobado por la Alta Dirección ni publicado internamente.
8	9.2.2 — Criterios, alcance y métodos definidos	CUMPLE	Cada auditoría del programa tiene criterios ISO y políticas funcionales asociadas, así como métodos definidos (revisión documental, entrevistas, muestreo).
9	9.2.3 — Independencia e imparcialidad del auditor	CUMPLE PARCIALMENTE	Se establece el principio, pero Telegram aún no cuenta con un equipo de auditoría interna formalmente separado del equipo de ingeniería. Se depende de auditores externos.
10	9.2.4 — Resultados comunicados a la dirección	CUMPLE	El flujo de auditoría establece la comunicación formal de hallazgos a Pavel y Nikolai Durov como parte del proceso.
11	9.2.5 — Documentación del programa y resultados	NO CUMPLE	No existe aún un repositorio centralizado y cifrado de evidencias de auditoría. Los logs inalterables están definidos como política, pero no implementados formalmente.
12	9.3.1 — Revisión periódica planificada	CUMPLE PARCIALMENTE	La cadencia de revisión está propuesta (anual + trimestral), pero no existe aún un calendario formal aprobado con fechas fijas.
13	9.3.2 — Entradas obligatorias consideradas	CUMPLE	Todos los elementos de entrada exigidos por la norma (acciones previas, contexto, KPIs, riesgos, retroalimentación) están incluidos en la tabla de revisión.



14	9.3.3 — Salidas documentadas con decisiones	CUMPLE PARCIALMENTE	Las categorías de decisión están definidas, pero no existe aún una plantilla de acta de revisión formalmente adoptada por la dirección de Telegram.
15	9.3.4 — Alineación con objetivos estratégicos	CUMPLE	La revisión contempla explícitamente la alineación del SGSI con la misión de privacidad y libertad de comunicación de Telegram.

Resultados Globales

7 CUMPLE	6 CUMPLE PARCIALMENTE	2 NO CUMPLE	15 TOTAL CRITERIOS	20/30 (67%) CALIFICACIÓN
--------------------	---------------------------------	-----------------------	------------------------------	--

CALIFICACIÓN FINAL: 20 / 30 puntos (67%) EN DESARROLLO — El SGSI tiene bases sólidas pero requiere acciones correctivas antes de la certificación.
--

Análisis de Brechas y Acciones Prioritarias

Las dos No Conformidades identificadas (criterios 9.1(f) y 9.2.5) representan los riesgos más altos de cara a una auditoría de certificación y deben ser atendidas de forma prioritaria:

- Criterio 9.1(f) — Responsables del análisis [NO CUMPLE]: Crear y aprobar formalmente una Política de Métricas del SGSI que designe nominalmente a los responsables de analizar y evaluar cada indicador. Plazo recomendado: 30 días.
- Criterio 9.2.5 — Documentación de auditorías [NO CUMPLE]: Implementar el repositorio centralizado de evidencias con política Write-Once y acceso restringido. Plazo recomendado: 60 días.

Los 5 criterios que Cumplen Parcialmente representan brechas de formalización: el contenido técnico existe, pero falta documentación oficial, firmas de autorización o plantillas aprobadas. Se recomienda cerrarlos antes del ciclo de auditoría de certificación:

- 9.1(b): Formalizar la metodología de validación de métodos de medición.
- 9.1(d): Crear Matriz RACI para la gestión y reporte de KPIs.



- 9.2.1: Publicar y aprobar formalmente el Programa Anual de Auditoría Interna 2026.
- 9.2.3: Formalizar el proceso de selección de auditores externos independientes.
- 9.3.1 / 9.3.3: Aprobar el calendario de revisiones por la dirección y la plantilla de actas.

Ciclo de Mejora Continua

Los hallazgos de esta evaluación alimentan directamente la Cláusula 10 (Mejora) del SGSI, donde las no conformidades identificadas se convierten en acciones correctivas formales con responsables y fechas límite, cerrando el ciclo PHVA y garantizando que el SGSI de Telegram evolucione de manera continua y demostrable.

Referencias

- International Organization for Standardization. (2022). ISO/IEC 27001:2022 — Information security management systems — Requirements. ISO.
- ISMS.online. (2025). ISO 27001 Requirement 9.1 – Monitoring, Measurement, Analysis and Evaluation (2022). Recuperado de: <https://www.isms.online/iso-27001/requirements-2022/9-1-monitoring-measurement-analysis-and-evaluation-2022/>
- ISMS.online. (2025). ISO 27001 Requirement 9.2 – Internal Audit. Recuperado de: <https://www.isms.online/iso-27001/requirements-2013/9-2-internal-audit-2013/>
- ISMS.online. (2025). ISO 27001 Requirements 9 – Performance Evaluation. Recuperado de: <https://www.isms.online/iso-27001/performance-evaluation-9/>
- Iseo Blue. (2025). ISO 27001 Clause 9 Performance Evaluation Explained. Recuperado de: <https://iseoblue.com/iso-27001/clauses/clause-9/>
- iso27001.com. (2025). ISO 27001:2022 Clause 9: Performance Evaluation & Internal Audit. Recuperado de: <https://iso27001.com/standard/clauses/9-performance-evaluation/>



SECCIÓN 8: OPERACIÓN

01 TRATAMIENTO DE LOS RIESGOS PARA LA SEGURIDAD DE LA INFORMACIÓN

Activo: Código fuente de las aplicaciones cliente

Riesgo asociado: Desconfianza del usuario o inyección de código malicioso en binarios de las tiendas de aplicaciones que no coinciden con el código público.

1. PLAN (Planificar)

- **Definición de Entornos:** Establecer las especificaciones técnicas de los entornos de compilación "limpios" y efímeros que permitan generar binarios idénticos (Reproducible Builds).
- **Cronograma de Sincronización:** Diseñar el flujo de trabajo para que el repositorio público (GitHub/GitLab) se actualice simultáneamente con el envío de versiones a las tiendas de aplicaciones.
- **Documentación de Compilación:** Crear guías paso a paso para que auditores externos puedan replicar el proceso de construcción desde el código fuente.

2. DO (Hacer)

- **Publicación de Repositorios:** Mantener actualizados los repositorios públicos para iOS, Android y Desktop con cada nueva versión lanzada.
- **Generación de Binarios:** Ejecutar el proceso de compilación en los entornos aislados definidos para asegurar que los artefactos finales sean reproducibles.
- **Firma de Código:** Aplicar las firmas digitales correspondientes tanto al código fuente como a los binarios para garantizar su integridad durante la distribución.

3. CHECK (Verificar)

- **Pruebas de Reproducibilidad:** Realizar comparaciones bit a bit entre los binarios generados internamente y los descargados de las tiendas oficiales (App Store, Google Play).
- **Auditoría de Terceros:** Monitorear y validar los reportes de la comunidad o de auditores externos que intentan verificar la coincidencia del código publicado.
- **Validación de Integridad:** Verificar que el hash del código en el repositorio coincida con la documentación de la versión publicada.



4. ACT (Actuar)

- **Corrección de Desviaciones:** Si se detecta una discrepancia entre el binario y el código fuente, se debe identificar la causa (ej. cambio en las dependencias) y corregir el entorno de compilación inmediatamente.
- **Actualización de Políticas:** Ajustar los manuales de compilación si las herramientas de las plataformas (XCode, Android Studio) cambian y afectan la reproducibilidad.
- **Mejora de Transparencia:** Implementar mejores herramientas de automatización en el CI/CD para reducir el error humano en la publicación de versiones.

Sección 10: Mejora

- **Riesgo Asociado de la Matriz:** I. Riesgo Extremo - No. 6: Código Fuente del Protocolo MTPProto.
- **Riesgo Teórico:** Descubrimiento de vulnerabilidades críticas por ingeniería inversa.
- **Valoración en Matriz:** Probabilidad (03) x Impacto (05) = Muy Alto / Extremo (15).
- **Política del SGSI Afectada:** Auditorías criptográficas constantes y control estricto de repositorios.

1. Qué ocurrió (Descripción de la No Conformidad y caso hipotético)

El 18 de abril de 2026, un investigador de seguridad externo notificó a través del programa *Bug Bounty* de Telegram el descubrimiento de una vulnerabilidad crítica de desbordamiento de búfer en el componente de cifrado del código fuente del protocolo MTPProto 2.0, la cual permitía realizar ingeniería inversa avanzada y deducir fragmentos de memoria efímera. La investigación interna reveló que la vulnerabilidad fue introducida en una actualización menor realizada tres semanas antes. El cambio en el código fuente omitió el control técnico estricto del repositorio y se publicó en producción sin haber pasado de forma obligatoria por la **auditoría criptográfica constante de terceros** estipulada en la política de seguridad, constituyendo una desviación directa al cumplimiento de los controles del SGSI.

2. Medidas de contención y mitigación (Consecuencias indeseables)

Inmediatamente después de la validación del reporte (tiempo de respuesta de 45 minutos):



- **Aislamiento del repositorio:** Se restringió temporalmente el acceso de escritura al repositorio principal del protocolo para congelar cualquier línea de desarrollo adyacente.
- **Despliegue de Parche Criptográfico:** El núcleo de ingeniería senior desarrolló y aplicó un parche de emergencia (*hotfix*) directo al código fuente para neutralizar la vulnerabilidad de ingeniería inversa.
- **Auditoría Retrospectiva Externa:** Se contrató de manera urgente a la firma externa encargada de las auditorías matemáticas del protocolo para analizar el parche en un entorno aislado y certificar de manera expés que la integridad criptográfica de MTPProto había sido completamente restablecida antes de liberar la actualización global a las aplicaciones cliente.

3. La causa raíz del suceso

Tras realizar el análisis mediante la metodología de los 5 *Porqués*, se determinó que la causa raíz fue una **falla en la configuración de la automatización (*pipeline*) de control del repositorio en el entorno de desarrollo seguro**.

Específicamente, una regla técnica que debía bloquear de forma mandatoria la fusión de ramas (*merge*) hacia la rama principal si no existía el certificado digital o token de aprobación de la auditoría criptográfica externa, fue desactivada manualmente de forma temporal durante una ventana de mantenimiento previa y no se volvió a activar por falta de una verificación automatizada posterior de cumplimiento técnico.

4. Las medidas adoptadas para eliminar la causa raíz (Acción Correctiva)

Para evitar la recurrencia de este fallo y blindar de forma permanente la política de la organización, se implementaron las siguientes acciones técnico-administrativas:

- **Endurecimiento Técnico de Repositorios (Control Estricto):** Se implementaron reglas de protección de rama inmutables en el control de versiones. A partir de esta fecha, el sistema exige de manera automatizada dos factores de validación inquebrantables: la firma criptográfica del líder del Núcleo de Ingeniería y el hash de aprobación emitido por el sistema de la firma auditora externa. Ningún usuario (incluidos administradores) puede evadir esta restricción.
- **Monitoreo Automático de Cumplimiento:** Se integró un bot de auditoría continua en el sistema de control de repositorios que escanea cada 60 minutos las configuraciones de seguridad de las ramas críticas. Si detecta que alguna regla de protección es modificada o desactivada, alerta instantáneamente al equipo de Ciberseguridad y revoca los accesos de forma preventiva.



5. Evaluación de la eficacia de las medidas adoptadas

Treinta días después de la implementación de las acciones correctivas (18 de mayo de 2026), el área de Seguridad Informática realizó la auditoría de seguimiento:

- Se extrajo el historial de auditoría inalterable (*logs*) del repositorio central, confirmando que se realizaron 8 fusiones (*merges*) de código al protocolo MTProto en este periodo.
- En el 100% de los casos, el entorno exigió y validó de forma correcta tanto la firma del núcleo de ingeniería como la certificación de la auditoría criptográfica externa antes de permitir el empaquetado del código.
- El bot de monitoreo automático reportó un correcto funcionamiento sin caídas.
- **Conclusión:** La acción correctiva se evalúa como **Eficaz**, habiendo mitigado el riesgo de inyección de vulnerabilidades explotables por ingeniería inversa mediante un control técnico estricto y automatizado del código fuente de nuestro protocolo principal.

